



Penetration Testing

Prepared by: Shikur Mehamed

Information Network Security Administration

AGENDA

- 01  Penetration Testing Methodology
- 02  Scoping & Rules of Engagement
- 03  Passive vs Active Reconnaissance
- 04  Network Scanning & Nmap Deep Dive
- 05  Service Fingerprinting & Enumeration
- 06  Full Recon & Target Profile Building

WHAT IS PENETRATION TESTING?

A simulated cyber attack against a system, network, or application to identify security weaknesses before real attackers do.



Authorized

Conducted with explicit written permission and defined scope



Methodical

Follows structured phases from recon to reporting



Actionable

Produces prioritized findings and remediation guidance

PENETRATION TESTING PHASES



TODAY'S FOCUS

Phases 1–3: Scoping & Rules of Engagement, Passive vs Active Reconnaissance, Network Scanning with Nmap, Service Fingerprinting, SMB & SNMP Enumeration, and building a complete target profile from a provided network.

SCOPING THE ENGAGEMENT

Clear scope prevents legal issues, wasted effort, and scope creep.

In-Scope Assets

- IP ranges & domains
- Specific applications
- Cloud environments
- Physical locations

Out-of-Scope

- Third-party systems
- Production critical paths
- Social engineering*
- Denial-of-service*

Constraints

- Testing windows
- Allowed techniques
- Notification rules
- Data handling rules

RULES OF ENGAGEMENT (RoE)



Authorized Contacts

Primary & backup points of contact for emergencies and escalation



Emergency Procedures

Stop conditions, incident response coordination, and kill-switch process



Legal Authorization

Signed contract, liability waivers, and get-out-of-jail-free letter



Technical Boundaries

Allowed tools, prohibited actions, rate limits, and time windows



Data Handling

How findings, credentials, and sensitive data must be stored & destroyed



Success Criteria

What constitutes engagement completion and acceptance of results

PASSIVE VS ACTIVE RECONNAISSANCE



PASSIVE RECON

- No direct interaction with target
- OSINT: WHOIS, DNS, search engines
- Social media & job postings
- Certificate transparency logs
- Shodan / Censys / public datasets
- Lower detection risk



ACTIVE RECON

- Direct interaction with systems
- Port scanning & service probes
- Banner grabbing & fingerprinting
- Vulnerability scanning
- Directory / API enumeration
- Higher detection & legal risk

PASSIVE RECONNAISSANCE TECHNIQUES

DNS & WHOIS

Domain registration, name servers, historical records, zone transfers (if allowed)

Search Engines

Google dorking, Bing, DuckDuckGo for exposed files, login pages, error messages

Certificate Logs

crt.sh, Censys – discover subdomains via issued TLS certificates

Public Scanners

Shodan, Censys, BinaryEdge – open ports, banners, vulnerabilities already indexed

Code & Docs

GitHub, Pastebin, documentation, job ads revealing tech stack

Social & People

LinkedIn, Twitter, employee emails, organizational structure

ACTIVE RECONNAISSANCE TECHNIQUES

- | | | |
|----|---------------------------|--|
| 01 | Host Discovery | ICMP, ARP, TCP/UDP ping sweeps to find live hosts |
| 02 | Port Scanning | TCP SYN, Connect, UDP, ACK scans to map open ports |
| 03 | Service Detection | Version probes, banner grabbing, protocol analysis |
| 04 | OS Fingerprinting | TCP/IP stack analysis, TTL, window size patterns |
| 05 | Vulnerability Scan | NSE scripts, Nessus, OpenVAS against discovered services |
| 06 | Directory Brute | Web path discovery, API endpoint enumeration |

NETWORK SCANNING FUNDAMENTALS

Goal: Discover live hosts, open ports, running services, and operating systems to build an attack surface map.

Host Discovery

- sn (ping scan)
- PR (ARP)
- PE/-PP/-PM

Port Scan Types

- sS SYN stealth
- sT Connect
- sU UDP

Timing & Evasion

- T0 to -T5
- f fragment
- mtu, decoys

Output Formats

- oN normal
- oX XML
- oA all

NMAP DEEP SCANNING

```
nmap -sn 192.168.1.0/24
```

Discover live hosts (no port scan)

```
nmap -sS -p- -T4 10.0.0.5
```

Full TCP SYN scan, all 65535 ports

```
nmap -sV -sC -O target
```

Version detection + default scripts + OS

```
nmap -sU --top-ports 100 target
```

UDP scan of top 100 ports

```
nmap -A -vv -oA fullscan target
```

Aggressive scan, verbose, all outputs

```
nmap --script vuln target
```

Run vulnerability detection scripts

NMAP SCRIPTING ENGINE (NSE)

default

Safe, useful scripts run with -sC

safe

Non-intrusive discovery scripts

vuln

Known vulnerability checks

auth

Authentication related scripts

discovery

Extra network/service discovery

brute

Credential brute-force modules

SERVICE FINGERPRINTING

Identify exact service name, version, and sometimes configuration to map to known vulnerabilities.

Banner Grabbing

```
nmap -sV  
nc target 22  
curl -I http://...
```

Protocol Probes

```
NSE scripts  
ssl-enum-ciphers  
http-headers
```

Manual Analysis

```
Wireshark  
Custom probes  
Error messages
```

PRO TIP

Always correlate version info with CVE databases (NVD, Exploit-DB). A precise version + known exploit can turn recon into a high-value finding.

SMB ENUMERATION

Server Message Block (ports 139/445) – rich source of shares, users, policies, and potential null sessions.

nmap

```
nmap -p 445 --script smb-enum-*,smb-os-discovery target
```

enum4linux

```
enum4linux -a target # all-in-one Linux enum
```

smbclient

```
smbclient -L //target -N # list shares (null)
```

rpcclient

```
rpcclient -U "" -N target # null session RPC
```

CrackMapExec

```
cme smb target -u '' -p '' --shares
```

Impacket

```
python3 lookupsid.py anonymous@target
```

SNMP ENUMERATION

Simple Network Management Protocol (UDP 161/162) – often misconfigured with public/private community strings.

COMMON COMMANDS

- `nmap -sU -p 161 --script snmp-* target`
- `snmpwalk -v2c -c public target`
- `snmp-check target -c public`
- `onesixtyone -c community.txt target`
- `braa public@target:.1.3.6.*`

WHAT YOU CAN LEARN

- System description & uptime
- Network interfaces & IPs
- Running processes & services
- Installed software versions
- User accounts (sometimes)
- Routing tables & ARP cache

FULL RECON WORKFLOW

1 Scope Review

Confirm in-scope ranges, RoE, and contacts

2 Passive OSINT

WHOIS, DNS, certs, Shodan, public data

3 Host Discovery

nmap -sn / ARP / masscan on scope

4 Port & Service Scan

Full TCP + top UDP, -sV -sC

5 Deep Enum

SMB, SNMP, HTTP, LDAP, etc.

6 Profile & Report

Consolidate findings into target profile

DISCOVERING HOSTS

Practical host discovery sequence for a provided target network:

1

```
nmap -sn -PE -PP -PS21,22,23,80,443,3389 -PA80,443 10.10.0.0/24
```

Multi-method ping sweep

2

```
nmap -PR 10.10.0.0/24 # if on same L2 segment
```

ARP discovery (fastest)

3

```
masscan -p0-65535 10.10.0.0/24 --rate 1000
```

Ultra-fast port sweep (optional)

4

```
fping -a -g 10.10.0.0/24 2>/dev/null
```

Alternative ICMP sweep



ENUMERATING SERVICES

RECOMMENDED DEEP SCAN

```
nmap -sS -sV -sC -O -p- -T4 --script=default,safe,discovery -oA target_full  
10.10.0.0/24
```

22

SSH

Banner, auth methods, weak keys

80/443

HTTP(S)

Headers, dirs, tech stack, TLS

139/445

SMB

Shares, users, null session

161

SNMP

Community strings, MIBs

389/636

LDAP

Anonymous bind, structure

3389

RDP

NLA status, version

BUILDING A TARGET PROFILE

Consolidate all recon data into a living document that guides later phases.

Network Map

- Live hosts & IPs
- Open ports matrix
- OS & service versions

Attack Surface

- Exposed services
- Known CVEs
- Misconfigurations

Credentials & Access

- Default creds found
- Null sessions
- Weak auth

Priorities

- High-value targets
- Low-hanging fruit
- Risk ranking



KEY TAKEAWAYS

1. Always start with clear scope and signed Rules of Engagement
2. Prefer passive recon first — reduce noise and legal risk
3. Nmap + NSE remains the core of network enumeration
4. SMB & SNMP often yield high-value information quickly
5. Build and maintain a living target profile throughout the engagement

Thank You

We appreciate your time and attention

Questions?

We'd love to hear your thoughts
